

Siber Güvenlik Mühendisliği Eğitimi

201 HAZIRLIK PROJESİ: "Blueprint & The Watcher"

ŞEYMANUR YILMAZ

- FAZ 1 -

BÖLÜM A

1. Windows Mimarisi: "Yetki Kimin Elinde?"

Administrator vs. SYSTEM: Admin bir kullanıcıdır, SYSTEM ise işletim sisteminin kendisidir. SYSTEM her şeye erişir. Neden hedefimiz? Çünkü Admin bile olsak bazı sistem dosyalarına veya kritik işlemlere doğrudan müdahale edemeyiz ama SYSTEM iken hiçbir kısıtlama kalmaz. Örneğin bazı servisler veya sistem süreçleri sadece SYSTEM yetkisiyle yönetilir. Bu yüzden saldırgan için gerçek kontrol noktası SYSTEM olmaktır. Yani Admin olmak güçlüdür ama SYSTEM olmak tam hakimiyettir.

UAC (User Account Control): O pencere aslında bir token kontrolüdür. Uygulamanın yüksek yetkiyle çalışıp çalışmayacağını sorar. Yani admin olsan bile her işlem otomatik olarak yüksek yetkiyle başlamaz. Bypass demek, kullanıcıya sormadan o yetkiyi gizlice almak demektir. Saldırgan bunu başardığında, fark edilmeden admin yetkisiyle işlem yapabilir ve sistemde daha rahat hareket eder.

Windows Services (Servisler): Eğer yol C:\Program Files\My App\service.exe ise ve tırnak yoksa; Windows bu yolu direkt okuyamaz, boşlukları ayırıcı gibi görür. Önce C:\Program.exe var mı diye bakar. Eğer yoksa sırayla C:\Program Files\My.exe gibi alternatifleri dener. En son gerçek dosyaya ulaşır. Ama eğer saldırgan C:\ dizinine Program.exe adında zararlı bir dosya koyabilirse; servis çalıştığında Windows gidip gerçek servis yerine bu zararlı dosyayı çalıştırır. Çünkü yolu yanlış yorumlamıştır. Bu servisler genelde SYSTEM yetkisiyle çalıştığı için, çalıştırılan zararlı dosya da SYSTEM yetkisiyle çalışır. Yani saldırgan direkt en yüksek yetkiyi elde etmiş olur. Zafiyetin mantığı tam olarak budur.

2. Mavi Takımın Gözü: "Sessizliği Bozmak"

SIEM / EDR Nedir? Event Viewer sadece o bilgisayara özel yerel bir log kayıdır. Büyük bir kurumda yüzlerce bilgisayar varsa, saldırgan birine girip logları silerse kimsenin haberi olmayabilir. Wazuh veya Splunk gibi SIEM sistemleri ise tüm logları merkezi bir yerde toplar. Yani saldırgan logları silse bile veriler çoktan merkeze gitmiş olur. Ayrıca farklı makinelerden gelen küçük olayları birleştirerek saldırının genel resmini ortaya çıkarır.

Gürültülü Araçlar: WinPEAS veya BloodHound gibi araçlar çok kısa sürede sistemde birçok yeri kontrol eder. Bu da anormal bir işlem yoğunluğu ve trafik oluşturur. Bu durum Mavi Takım için hemen dikkat çeker. Örneğin sürekli yeni process oluşumu (Event ID 4688) gibi loglar üretilir ve EDR sistemleri alarm verir. Gürültülü çalışmak, sistemde çok fazla iz bırakmak demektir.

BÖLÜM B

Cephe 1: Sistemin Kalbi (Windows İşletim Sistemi)

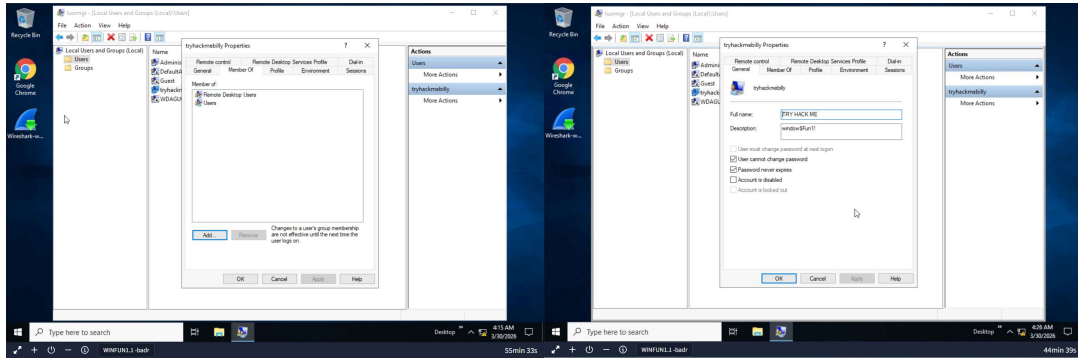
Hedef: TryHackMe - Windows Fundamentals 1 & 2 Analiz

Amacı: Windows'un kullanıcı yetkilendirme mimarisini, servis yapısını ve kayıt defteri mantığını ezbere kaçmadan teknik olarak kavramak.

Operasyonel Bulgular ve Analiz

Kimlik ve Grup Yönetimi (Local Users and Groups)

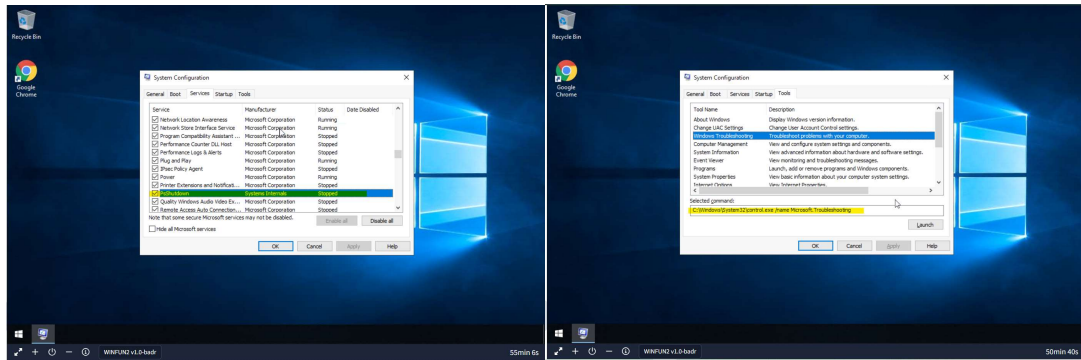
THM üzerinde yaptığım incelemede tryhackmebilly kullanıcısının özelliklerini kontrol ettim. Görsellerde görüldüğü üzere bu kullanıcı sadece Remote Desktop Users ve Users grubuna üye.



Bu kullanıcı sistem üzerinde kısıtlı haklara sahiptir. Administrator yetkisi olmadığı için sistem üzerinde kritik değişiklikler yapamaz. PrivEsc senaryolarında hedefimiz, bu tarz düşük yetkili bir kullanıcıdan SYSTEM seviyesine çıkmaktır.

2. Servis Yapısı ve Sistem Araçları (MSConfig & Services)

msconfig ve servis yapılarını inceledim. Services sekmesinde çalışan servislerin üretici bilgileri ve durumları gözlemlendi. Ayrıca Tools sekmesinde Windows'un yerleşik araçlarına erişim sağlandığı görüldü.



Bir servisin sadece çalışıyor olması yeterli değildir. Önemli olan o servisin hangi dosya yolundan çalıştırıldığıdır.

Görsellerde görüldüğü gibi komutlar genelde:

- C:\Windows\System32\... -

yolundan çağrılıyor.

Eğer bu yollar:

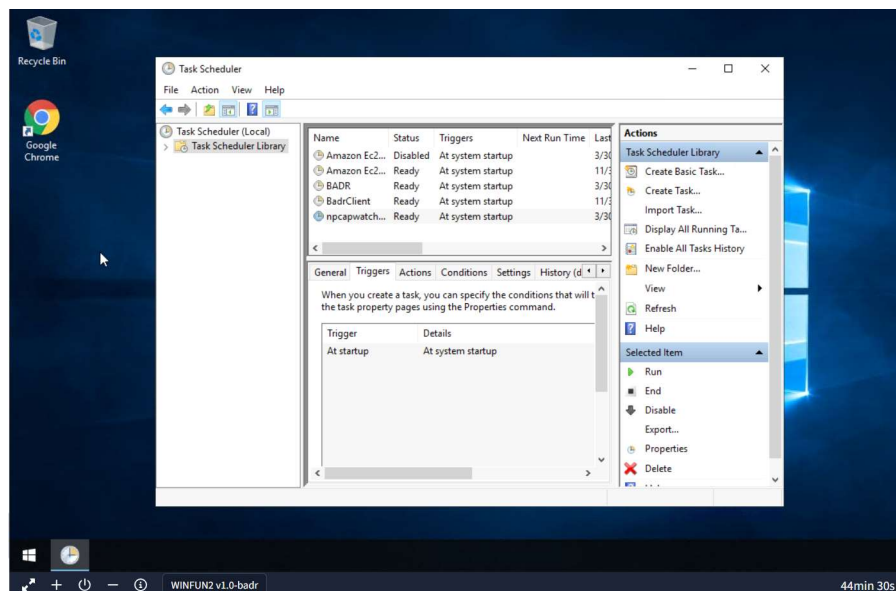
- tırnaksız (unquoted)

- boşluk içeriyorsa

Unquoted Service Path zafiyeti oluşabilir.

3. Görev Zamanlayıcı (Task Scheduler)

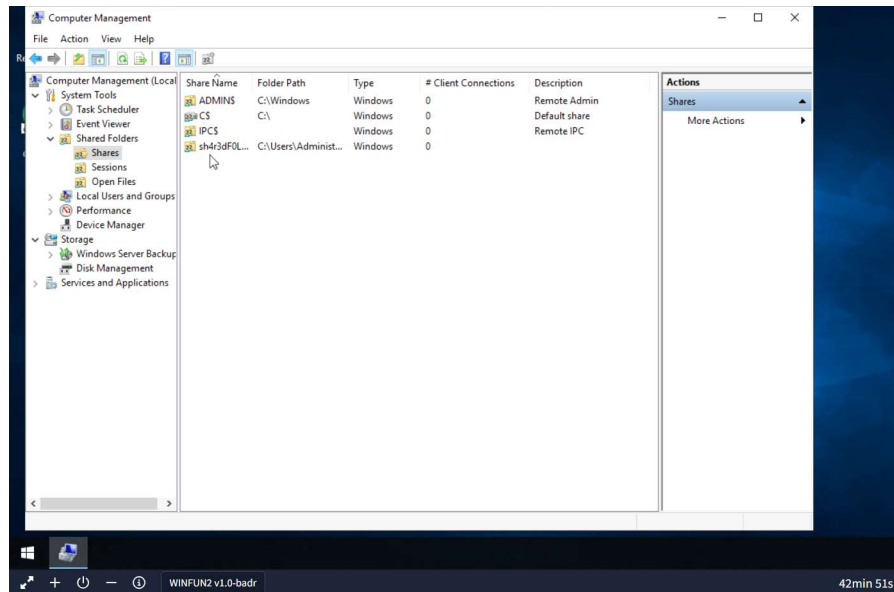
Task Scheduler üzerinden sistemde çalışan görevleri inceledim. Özellikle npcapwatchdog görevinin tetiklenme zamanını analiz ettim.



Bu görevlerin ne zaman ve hangi yetkiyle çalıştığını bilmek önemlidir. Eğer yanlış yapılandırılmışsa, saldırgan kendi payload'ını bu görevler üzerinden çalıştırabilir.

4. Paylaşımlar (Shared Folders)

Computer Management üzerinden paylaşılan klasörleri inceledim.



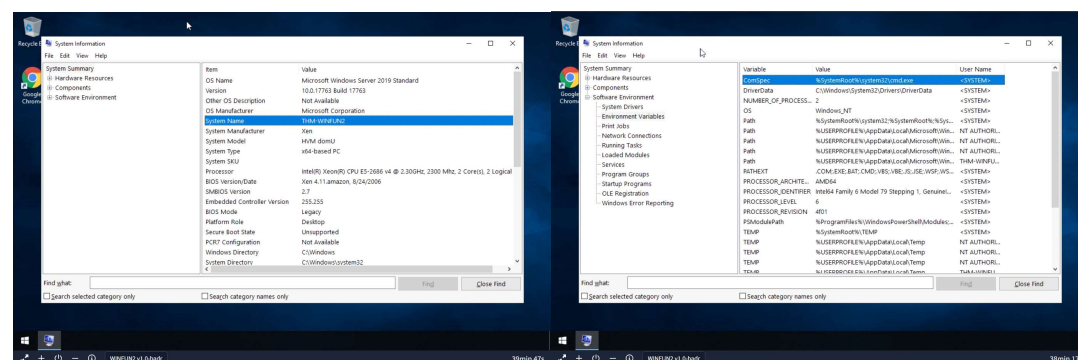
Gözlemlenen paylaşımlar:

- ADMIN\$
- C\$
- IPC\$

Ş ile biten paylaşımlar gizli paylaşımlardır ve genelde admin erişimi içindir. Bu paylaşımlar yanlış yapılandırılmışsa sistem sızması için kullanılabilir.

5. Sistem Bilgisi ve Environment Variables

msinfo32 aracı kullanılarak sistem bilgilerini inceledim.



ComSpec = %SystemRoot%\system32\cmd.exe

Bu değişken sistemin komut yorumlayıcısını gösterir. Ayrıca dikkat edilmesi gereken en önemli nokta:

Bu işlemler <SYSTEM> yetkisi ile çalışıyor

Bu da bize şunu gösterir:

Windows'un kritik işlemleri kullanıcıdan bağımsız olarak SYSTEM seviyesinde yürütülür.

Registry ve Yetkilendirme

Soru: Kayıt defteri (Registry) neden kritiktir ve zayıf izinler nasıl hak yükseltmeye yol açar?

Cevap: Registry, Windows'un neyi nasıl yapacağını belirleyen merkezi bir yapılandırma veritabanıdır. Hangi servis hangi dosyayı çalıştıracak, hangi program neyi açacak gibi tüm kritik bilgiler burada tutulur. Neden kritik? Çünkü burada yapılan bir değişiklik, Windows tarafından doğrudan uygulanır. Normalde bir servisin çalıştırılacağı yol (ImagePath) sadece Administrator tarafından değiştirilebilir. Ancak bu anahtar üzerinde zayıf izinler varsa, normal bir kullanıcı bu yolu değiştirebilir. Saldırgan bu yolu kendi zararlı dosyasına yönlendirir. Servis yeniden çalıştığında: Windows saldırganın dosyasını SYSTEM yetkisiyle çalıştırır. Sonuç olarak tam yetki ele geçirilmiş olur.

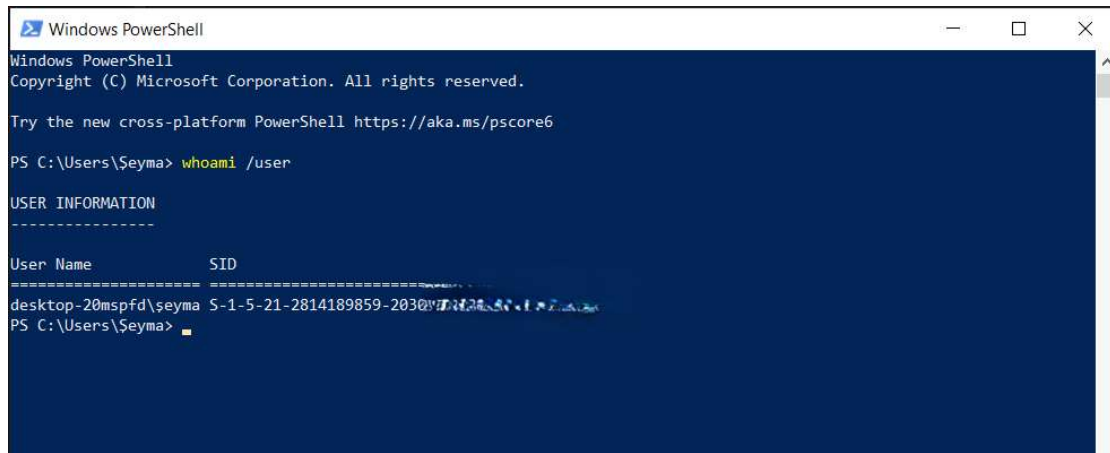
- FAZ 2 -

BÖLÜM C

Cephe 1: Kimlik ve Yetki Haritası

Sisteme sızan bir saldırganın ilk sorusu "Ben kimim?" olmalıdır. Kendi sistemimde bu sorguları yürüttüm.

Komutlar: whoami /user, whoami /priv



```
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Try the new cross-platform PowerShell https://aka.ms/pscore6

PS C:\Users\Şeyma> whoami /user

USER INFORMATION
-----
User Name                SID
-----
desktop-20mpfd\şeyma     S-1-5-21-2814189859-2030912345-1595760160
PS C:\Users\Şeyma>
```

```

PRIVILEGES INFORMATION
-----
Privilege Name      Description      State
=====
SeShutdownPrivilege Sistemi kapat    Disabled
SeChangeNotifyPrivilege Çapraz geçiş denetimini atla Enabled
SeUndockPrivilege Bilgisayarı takma biriminden çıkar Disabled
SeIncreaseWorkingSetPrivilege İşlem çalışma kümesini artır Disabled
SeTimeZonePrivilege Saat dilimini değiştir Disabled
PS C:\Users\Şeyma>

```

```

Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Try the new cross-platform PowerShell https://aka.ms/pscore6

PS C:\Users\Şeyma> whoami
desktop-20mspf\şeyma
PS C:\Users\Şeyma> net user şeyma
Kullanıcı adı          Şeyma
Tam ad                 Şeymanur Yılmaz
Açıklama
Kullanıcı açıklaması
Ülke/bölge kodu        000 (Sistem Varsayılan değer)
Hesap etkin            Evet
Hesap zaman aşımı      Asla

Parolanın son ayarlanmadı 3.01.2025 14:23:06
Parola süre sonu        Asla
Değişebilir parola      3.01.2025 14:23:06
Parola gerekli          Hayır
Kullanıcı parolayı değiştirebilir Evet

İzin verilen iş istasyonları Tümü
Oturum açma kodu
Kullanıcı profili
Ana izin
Son oturum açma        3.01.2025 14:23:02

İzin verilen oturum açma saatleri Tümü

Yerel Grup Üyeliği      *Administrators
Genel Grup Üyeliği      *Yok
Komut başarıyla tamamlandı.

PS C:\Users\Şeyma>

```

Yapılan analiz sonucunda SID numaramı ve sahip olduğum ayrıcalıkları (Privileges) görüntüledim. SeShutdownPrivilege veya SeChangeNotifyPrivilege gibi standart kullanıcı haklarına sahip olduğumu, ancak SeDebugPrivilege gibi yüksek yetkili hakların devre dışı olduğunu saptadım. Bu, sistemde şu an 'Kısıtlı Kullanıcı' profilinde olduğumu kanıtlar.

Cephe 2: Servis ve Dosya Yolu Analizi

Arka planda çalışan servislerin yapılandırma hataları, Windows sistemlerdeki en büyük zafiyet kaynaklarından biridir.

Komutlar: sc qc Spooler komutuyla servis yolunu ve yapılandırmasını denetledim.

```
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Try the new cross-platform PowerShell https://aka.ms/pscore6

PS C:\Users\Seyma> sc qc Spooler
PS C:\Users\Seyma> sc qc spooler
PS C:\Users\Seyma> sc.exe qc spooler
[SC] QueryServiceConfig SUCCESS

SERVICE_NAME: spooler
        TYPE               : 110  WIN32_OWN_PROCESS (interactive)
        START_TYPE          : 2    AUTO_START
        ERROR_CONTROL       : 1    NORMAL
        BINARY_PATH_NAME    : C:\Windows\System32\spoolsv.exe
        LOAD_ORDER_GROUP    : SpoolerGroup
        TAG                 : 0
        DISPLAY_NAME        : Yazdırma Biriktiricisi
        DEPENDENCIES        : RPCSS
                          : http
        SERVICE_START_NAME  : LocalSystem
PS C:\Users\Seyma>
```

Spooler servisinin BINARY_PATH_NAME çıktısını inceledim. Yolu tırnak içinde olması veya boşluk içermeyen bir dizinde bulunması (Örn: C:\Windows\System32\spoolsv.exe), sistemimin Unquoted Service Path zafiyetine karşı güvenli olduğunu ispatlamaktadır. Windows bu yolu okurken herhangi bir 'yol kesme' (path interception) saldırısına imkan tanımaz.

Cephe 3: Profesyonel Değerlendirme (Security Assessment)

Kendi yerel sistemimde gerçekleştirdiğim bu mikro-keşif operasyonunu bir Mavi Takım (Savunmacı) analisti perspektifiyle değerlendirdiğimde, teknik yapılandırma ile kullanıcı yetkilendirmesi arasında belirgin bir tezat saptadım. Ekran görüntülerinde de görüldüğü üzere yürüttüğüm net user sorgusu, aktif olarak kullandığım hesabın doğrudan Administrators grubuna dahil olduğunu ve dolayısıyla sistem üzerinde sınırsız yetkiye sahip olduğunu somut bir şekilde ortaya koymaktadır. Her ne kadar Spooler gibi kritik servislerin dosya yolları güvenli ve Unquoted Service Path zafiyetine karşı dirençli yapılandırılmış olsa da, en yüksek yetki grubunda bulunmam sistemin en zayıf halkasını oluşturmaktadır. Sonuç olarak, işletim sistemim teknik yapılandırma hataları açısından temiz bir profil çizse de, siber güvenliğin temel taşlarından biri olan En Az Yetki Prensipli (Least Privilege) ihlal edilmiştir. Olası bir sızma girişiminde saldırganın ek bir efor sarf etmeden tam yetki kazanmasını engellemek adına, günlük operasyonlarda standart bir kullanıcı hesabı kullanılması ve yönetici yetkilerinin yalnızca ihtiyaç anında (UAC eşliğinde) tetiklenmesi kritik bir güvenlik gerekliliğidir.

BÖLÜM D

1. "Yakalanmadan Yükselmek" (Evasion & LOLBAS Mantığı)

Bir Red Team uzmanı olarak, WinPEAS gibi gürültülü (noisy) ve imzasız araçların EDR/SIEM sistemleri tarafından kolayca engellenebileceğinin farkındayım. Bu tür bir engelleme durumunda operasyonu durdurmak yerine, "Living Off The Land" (LOLBAS) konseptine geçiş yaparak sistemde zafiyet aramaya devam ederim. LOLBAS, dışarıdan herhangi bir üçüncü parti yazılım getirmeden, Windows'un kendi bünyesinde bulunan ve işletim sistemi tarafından "güvenilir" (signed) olarak kabul edilen sc, icacIs, whoami, net ve reg gibi meşru araçları kullanarak sızma faaliyetlerini sürdürme sanatıdır. Bu yöntemin Evasion (atlatma) başarısındaki kritik rolü, EDR sistemlerinin çalışma mantığından kaynaklanmaktadır; güvenlik yazılımları bilinmeyen .exe dosyalarını anında karantinaya alırken, sistemin temel işleyişi için gerekli olan powershell.exe veya findstr gibi araçları engellemekte zorlanır. Dolayısıyla, meşru araçlarla yapılan sorgular "normal bir sistem yöneticisi aktivitesi" gibi görünerek radarın altında kalmayı ve SOC ekibine yakalanmadan ilerlemeyi mümkün kılar.

2. Çözüm Üretmek (Mitigation & Hardening)

Siber güvenlik mühendisliği disiplini, tespit edilen bir zafiyeti sömürmenin ötesinde, bu zafiyetin kökten çözülmesini ve sistemin sıkılaştırılmasını (Hardening) gerektirir. "Unquoted Service Path" zafiyetine karşı Sistem Yöneticilerine (Sysadmin) vereceğim temel talimat, tüm üçüncü parti yazılım ve servislerin ImagePath değerlerinin taranması ve dosya yolunda boşluk barındıran tüm girdilerin çift tırnak (") içine alınarak stabilize edilmesidir. Eş zamanlı olarak, "Weak Registry Permissions" riskini bertaraf etmek için kritik servislerin kayıt defteri anahtarları (HKLM\System\CurrentControlSet\Services) üzerinde sıkı bir Erişim Kontrol Listesi (ACL) denetimi yapılmalıdır. Bu bağlamda, standart kullanıcıların (Users) yazma yetkileri derhal kaldırılmalı, bu anahtarlar "Salt Okunur" hale getirilmeli ve tam kontrol yetkisi yalnızca SYSTEM ile Administrators gruplarına tanımlanmalıdır. Bu sayede, "En Az Yetki Prensibi" (Least Privilege) hayata geçirilerek saldırganların servis yollarını veya yapılandırma dosyalarını manipüle etmesi teknik olarak imkansız hale getirilir.